SIMATS ENGINEERING

ASSESSMENT TOOL 1 | REPORT ANALYSIS

Course Name	Ethical Hacking
Course Code	ITA1409
Course Outcome	CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.
Student Name / Reg No	B Kirthanaa / 192324244
Assessment	CO2 – AT1 (Report Analysis)

CO2 – AT1: Report Analysis – Solutions

Question 1 – Nmap Scan Report Analysis

> A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system.

Answer: Security Analysis of the Nmap Scan of 192.168.1.10

1. Understanding the Scenario

In this scenario, I am the security analyst who has to read the Nmap report and turn it into a risk assessment. Nmap (Network Mapper) is a port-scanning and footprinting tool. It sends probes to a target and reports which ports accept connections (open), which refuse them (closed) and which are silently dropped by a firewall (filtered). With the options for version detection (`-sV`) and OS detection (`-O`), it also reports the software name, its version and the likely operating system. This is active footprinting, the first technical step an attacker or an ethical hacker performs, so the report shows exactly what an attacker would learn about the system.

Facts given in the question

- The target is 192.168.1.10 and the tool used is Nmap.
- The open ports include HTTP (80), SSH (22) and MySQL (3306).
- The report also lists the operating system and the service versions.

Facts that are not given

The question does not give the exact version numbers, the full list of ports, whether the host is reachable from the internet, what data the database stores, or whether a firewall is in place. I have not assumed these as facts. The version numbers in Figure 1.1 come from the lab replica of the target and are used only to show how a real report is analysed. Also, 192.168.1.10 is a private (RFC 1918) address, so the host is internal unless it is published through NAT or port forwarding.

2. Interpreting the Report

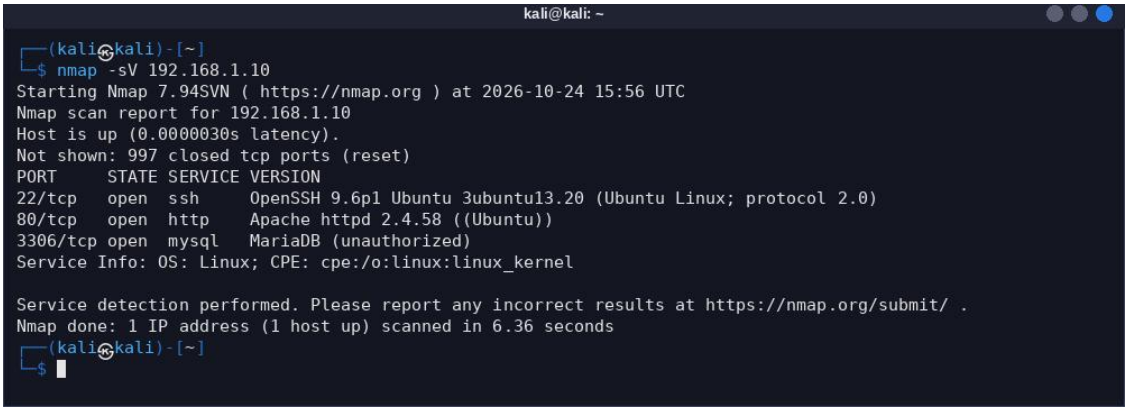


Figure: Nmap service-version scan (nmap -sV) of 192.168.1.10 – lab output

The key observations from the output are:

- **Host is up and responds quickly:** the target is live and reachable from the scanning machine, so any weakness found can be tested directly.
- **997 closed ports and 3 open ports:** the attack surface is small, which is good, but all three open services are high-value services (a website, remote administration and a database).
- **Version banners are visible:** each service tells the scanner its exact product and version. This helps an attacker search for known vulnerabilities (CVEs) that match those versions.
- **Operating system is visible:** the service information shows the host runs Linux, and the Apache banner adds “Ubuntu”. This narrows the attacker's choice of tools and local privilege-escalation techniques.

Port	Service	Sample Version	Normal Purpose	Observation
22/tcp	SSH	OpenSSH 9.6p1	Encrypted remote administration	Open to the scanner; login attacks possible; exact version disclosed
80/tcp	HTTP	Apache httpd 2.4.58 (Ubuntu)	Public web content	Plain-text protocol; web-application attack surface; version and OS disclosed
3306/tcp	MySQL	MariaDB (MySQL-compatible)	Database for the application	Database port reachable from the network; Nmap could not log in (“unauthorized”)
OS	Linux	Service Info: OS Linux	Operating system	OS family leaked through service banners

3. Security Risks of the Identified Services

3.1 HTTP (Port 80)

- **No encryption:** HTTP sends data in clear text. Anyone on the same network path can sniff logins, session cookies and form data (man-in-the-middle, session hijacking).

- **Web application vulnerabilities:** a web server is only as safe as the application behind it. Common flaws from the OWASP Top 10, such as SQL injection, cross-site scripting (XSS), broken authentication and security misconfiguration, can give an attacker access to data or the server.
- **Patching and banner exposure:** the banner shows the exact Apache release. If it is not kept updated, publicly known vulnerabilities for that release can be used, and the banner tells the attacker which ones to try.
- **Information leakage:** default pages, directory listing, verbose error messages and the `Server` header reveal technology details that help further footprinting.

3.2 SSH (Port 22)

- **Brute-force and credential-stuffing attacks:** if password login is allowed, an attacker can try common or leaked passwords repeatedly. A weak password on any account gives a full command shell.
- **Weak configuration:** direct root login, no account lockout and no multi-factor authentication increase the chance of success.
- **Version exposure:** the banner shows the exact OpenSSH release. Older releases have had known weaknesses (for example, versions up to 7.7 are affected by a username-enumeration flaw, CVE-2018-15473), so the service must be kept patched.
- **High impact:** SSH is an administrative channel. Successful access allows data theft, installing backdoors and moving to other systems (lateral movement).

3.3 MySQL (Port 3306)

- **Database exposed to the network:** a database should talk only to the application server. When port 3306 is reachable by any host, an attacker can attempt to log in directly, bypassing the web application.
- **Weak, default or empty passwords:** accounts such as `root` with a weak password, or anonymous users left from installation, are a very common finding.
- **Patching and support:** the scan identifies a MySQL-compatible server (MariaDB). The database must stay on a supported release, because unsupported branches such as MySQL 5.7 (end of life since October 2023) no longer receive security fixes.
- **Data at risk:** the database holds the most valuable asset (customer, financial or business records), so a breach affects confidentiality and integrity. Over-privileged accounts may also read or write files on the server.
- **Unencrypted connections:** without TLS, credentials and query data can be captured on the network.

3.4 Operating System

If the Linux kernel and packages are old or unpatched, they can allow a local attacker, or an attacker who already has a low-privilege shell, to become root through a known privilege-escalation flaw. Knowing the OS family helps the attacker to choose the right method.

3.5 Risk Rating Summary

Service	Likelihood	Impact	Risk Level	Main CIA Property Affected

Service	Likelihood	Impact	Risk Level	Main CIA Property Affected
MySQL 3306	High	Very high	Critical	Confidentiality, Integrity
HTTP 80	High	High	High	Confidentiality, Integrity, Availability
SSH 22	Medium	Very high	High	Confidentiality, Integrity, Availability
OS / host	Medium	High	Medium	Integrity, Availability

The ratings are my qualitative judgement from the type of service and its exposure; a formal assessment would also use CVSS scores for the real versions found.

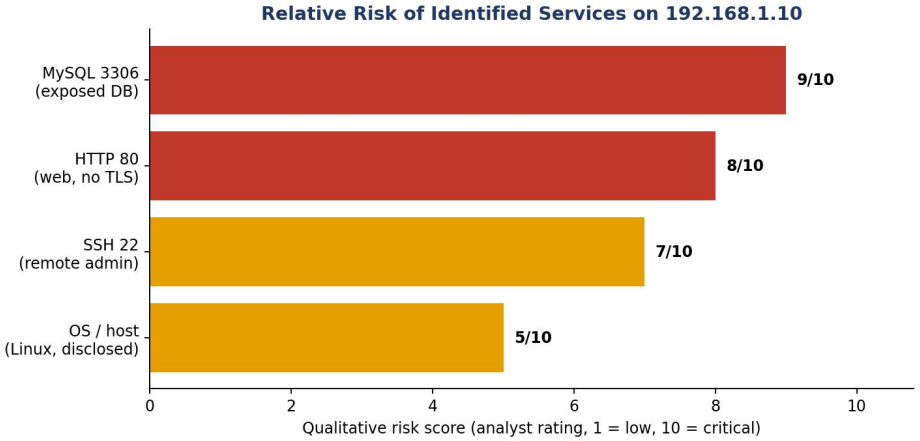


Figure: Relative risk of the services found by the scan (analyst rating)

4. How an Attacker Could Exploit These Services

The following is a conceptual description for defence purposes. It follows the standard ethical-hacking phases and shows why each finding in the report matters.

- **Phase 1 – Reconnaissance and footprinting:** the attacker runs the same Nmap scan. The report gives the open ports, software versions and OS. This is the report that is being analysed here.
- **Phase 2 – Enumeration and vulnerability matching:** the attacker compares the banners with public vulnerability databases (CVE, NVD, Exploit-DB) and checks the web application for the weaknesses listed above.
- **Phase 3 – Gaining access:** the likely routes are (a) a flaw in the web application, such as SQL injection, which gives access to the database or the server; (b) a password-guessing attack against SSH or MySQL; or (c) a direct login to the exposed MySQL port with a weak or default account.
- **Phase 4 – Post-exploitation:** after getting a foothold, the attacker tries to become root with a local flaw, steals or changes database records, installs persistence and uses the host as a pivot to attack other machines.

The most dangerous combination is a web application flaw together with an exposed database port. The first gives the attacker a way in and the second lets the attacker reach the data with little further effort. This is why defence needs several layers instead of a single fix.

5. Recommended Security Measures

5.1 Network-Level Controls

- Apply a **default-deny firewall** policy (for example UFW, iptables or a network firewall). Allow only required traffic.
- **Block port 3306 from everything except the application server**, or bind MySQL to `127.0.0.1` if the application runs on the same host.
- Allow **SSH only from an administrator IP range or through a VPN or bastion host**.
- Place the web server in a DMZ and the database in a separate internal network segment.

5.2 Service Hardening

Service	Recommended Measures
HTTP / Apache	Redirect all traffic to HTTPS with a valid TLS certificate and HSTS; update Apache to a supported version; set `ServerTokens Prod` and `ServerSignature Off`; disable directory listing and unused modules; deploy a web application firewall (for example ModSecurity); test the application for OWASP Top 10 flaws and fix them using parameterised queries and input validation.
SSH	Use key-based authentication and disable passwords (`PasswordAuthentication no`); disable root login (`PermitRootLogin no`); restrict users with `AllowUsers`; enable multi-factor authentication; install Fail2Ban or similar to block repeated failures; keep OpenSSH updated.
MySQL	Upgrade to a supported version (MySQL 8.x); run `mysql_secure_installation`; remove anonymous users and the test database; use strong unique passwords and least-privilege accounts (no remote root); enforce TLS for connections (`require_secure_transport=ON`); disable the `FILE` privilege for application users; enable audit logging.
Operating system	Apply security updates regularly (patch management); update to a supported kernel; follow a hardening baseline such as the CIS Benchmark; enable SELinux or AppArmor; remove unused packages and services.

5.3 Monitoring and Governance

- Enable and centralise logs (SSH, web server, database) and send alerts to a SIEM; use an intrusion detection/prevention system (IDS/IPS) to detect scans and brute-force attempts.
- Run regular vulnerability scans and penetration tests, and re-scan after every change.
- Maintain a patch-management and asset-inventory policy, and keep tested backups of the database.

5.4 Verification After Hardening

After the controls are applied, the scan must be repeated from an untrusted host to confirm that the changes work. Figure 1.4 shows the result in the lab: SSH and MySQL are now reported as filtered (blocked by the firewall), and Apache no longer reveals its version or operating system. Port 443 is shown as closed because HTTPS has still to be enabled; this is the next hardening step.



Figure: Re-scan after hardening – SSH and MySQL filtered, Apache version banner hidden

6. Prioritised Action Plan

Priority	Action	Suggested Time
1 – Critical	Block external access to port 3306; change all weak database passwords; remove anonymous users	Immediately (within 24 hours)
2 – High	Restrict SSH to admin IPs, disable password login and root login; enable HTTPS	Within 1 week
3 – High	Upgrade Apache, OpenSSH and MySQL to supported versions; apply OS patches	Within 2 weeks
4 – Medium	Deploy WAF, Fail2Ban, central logging and alerts	Within 1 month
5 – Ongoing	Scheduled scans, penetration tests, patch management and staff review of the firewall rules	Monthly / quarterly

7. Comparison: Before and After Hardening

Area	Before (Scan Result)	After (Recommended State)
SSH 22	Open to any host; passwords accepted	Filtered; key-only login from admin IPs/VPN
HTTP 80	Clear-text site; version banner shown	HTTPS with HSTS; banner hidden; WAF in front
MySQL 3306	Reachable from the network	Not reachable externally; supported version; TLS; least privilege
OS	OS family disclosed by banners	Patched; hardened baseline; minimal banners
Monitoring	No evidence of logging or alerts	Central logs, IDS/IPS and alerts

8. Conclusion

The Nmap report shows a small but sensitive attack surface: an unencrypted web server, a remotely reachable SSH service and an exposed MySQL database, all with visible version information. The greatest risk is the exposed database port combined with web or password weaknesses, because it leads directly to the data. The system can be protected by closing unnecessary exposure with a firewall, hardening and updating each service, using encryption and strong authentication, limiting privileges, and monitoring the host continuously. A re-scan after the changes confirms that the risk has been reduced.

Question 2 – GoPhish Phishing Campaign Analysis (20 Marks)

> A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

1. Understanding the Scenario

Phishing is a social engineering attack in which an attacker sends a message that looks genuine in order to trick a person into clicking a link, giving a password or opening a malicious file. GoPhish is an open-source phishing simulation framework. The organisation uses it with management approval to send a controlled fake phishing email to employees and to record who opens it, clicks the link, submits data on the fake login page or opens an attachment. The aim is to measure human risk and improve training, not to punish employees. Because the campaign is a simulation, the numbers show what would happen in a real attack.

Facts given in the question

- The organisation is ABC Technologies Pvt. Ltd. and the tool is GoPhish.
- 40% of employees clicked the phishing link.
- 20% entered their login credentials.
- Several users downloaded a malicious attachment.

Facts that are not given

The question does not give the number of employees, the exact number of attachment downloads, the departments involved, how many employees reported the email, the email theme or the time taken to click. Therefore, for the charts only, I show percentages (per 100 employees), and the attachment result is shown as “several users” without inventing a percentage. The same conclusions apply for any total number of employees.

2. Interpreting the Report

Metric	Result	What It Means
Link clicked	40%	Two in every five employees trusted a fake email. An attacker needs only one victim, so this rate would almost certainly lead to a breach.
Credentials entered	20%	Half of the people who clicked (20 out of 40) also typed their username and password into the fake page. They did not check the web address or the page.
Attachment downloaded	“Several users”	Some employees opened a file from an unverified source. In a real attack this could install malware or ransomware.
Did not click	60% (derived)	Most employees did not click, which shows training can work, but this group must be larger.
Reported the email	Not given	The reporting rate is a key measure of a healthy security culture and should be measured in the next campaign.

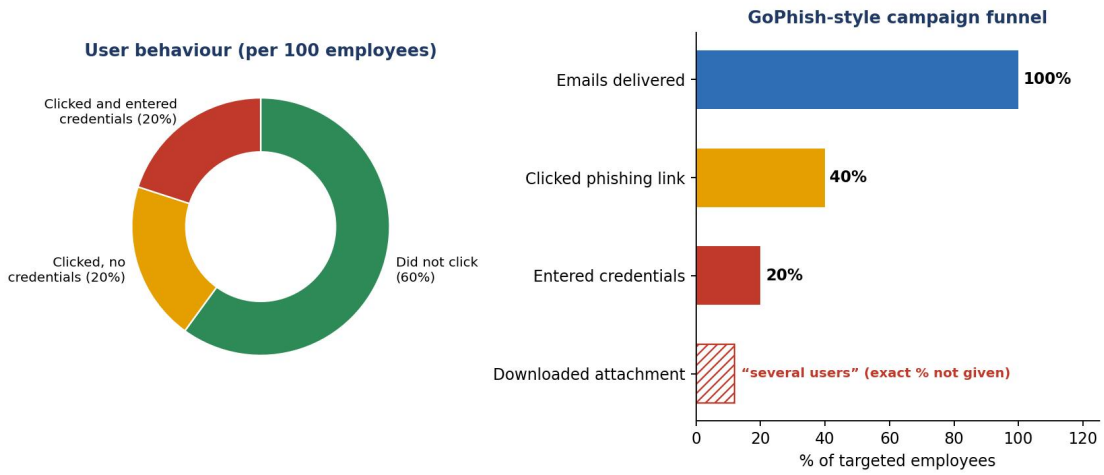


Figure: Phishing campaign results – user behaviour and campaign funnel

The most important conclusion is that the failures are layered. The attack passed the email filter, convinced the user, and then ran on the endpoint. In a real incident, any one of these three stages would be a point where a better control could have stopped it.

3. Security Weaknesses Demonstrated

Category	Weakness	Evidence in the Report	Risk
Human	Low phishing awareness; users cannot spot suspicious links, sender addresses and urgent language	40% clicked the link	Initial compromise
Human	Credentials entered on an unverified page; no habit of checking the URL or HTTPS certificate	20% entered credentials	Account takeover, data theft, lateral movement
Human	Opening attachments from unknown or unexpected senders	Several users downloaded the file	Malware, ransomware, remote access
Technical	Email gateway did not block the message, rewrite the link or detonate the attachment	The mail reached users and the link/file worked	Phishing reaches inboxes
Technical	Endpoint allowed the file to be saved or run; stolen passwords alone may be enough to log in (no strong MFA)	Downloads and credential entry succeeded	Malware execution; account misuse
Process	No clear or easy way to report suspicious email; incident reporting is not part of daily practice	No reporting figure	Slow detection and response
Policy	No enforced rules on attachment handling, verification of requests or password reuse	Behaviour across all three actions	Inconsistent security behaviour

Social Engineering Principles Used by the Attacker

Phishing succeeds because it uses normal human psychology. The campaign most likely used one or more of these principles:

- **Authority:** the email appears to come from IT, HR or a manager, so people obey without checking.
- **Urgency and fear:** messages such as "your account will be locked today" stop people from thinking carefully.
- **Curiosity and reward:** attachments such as "salary revision" or "bonus list" encourage people to open them.
- **Trust and familiarity:** a copied company logo and style make the fake page look genuine.

4. Recommended Controls

4.1 User Awareness Programs

- **Onboarding and periodic training:** a short mandatory course for every new employee and an annual refresher, covering phishing signs (sender address, mismatched links, urgency, unexpected attachments).
- **Micro-learning:** short monthly videos or quizzes, which work better than one long yearly session.
- **Regular simulated campaigns with GoPhish:** run them every quarter with different themes and rising difficulty. Compare the results with this baseline.
- **Just-in-time coaching:** when a user clicks a simulated link, show an immediate teaching page. The approach should be supportive and not punitive, so that people are not afraid to report mistakes.
- **"Report Phish" button:** train staff to report suspicious emails with one click, and give quick feedback to the reporter.
- **Role-based training:** extra training for high-risk groups such as finance, HR, administrators and senior management, who are common targets.
- **Security champions and awareness material:** posters, newsletters and short stories of real incidents to keep the topic visible.

4.2 Email and Technical Security Controls

- **SPF, DKIM and DMARC:** authenticate email so that attackers cannot easily spoof the company domain. DMARC with a `p=reject` policy tells receivers to refuse forged mail.
- **Secure email gateway:** spam and phishing filters, reputation checks, and blocking of look-alike domains.
- **Link protection:** rewrite URLs and scan them again at the time of the click; use DNS or web filtering to block known phishing sites.
- **Attachment protection:** sandbox (detonate) attachments before delivery, block executable and script file types and macro-enabled Office files from external senders.
- **External sender banner** on messages from outside the organisation.
- **Multi-factor authentication (MFA):** preferably phishing-resistant (FIDO2 security keys or passkeys), so that a stolen password alone is not enough.

- **Endpoint protection:** EDR/antivirus, disabling macros from the internet, application allow-listing and least-privilege user accounts.
- **Password manager:** it fills credentials only on the correct domain, which helps users notice fake sites.



Figure: SPF, DKIM and DMARC records queried with dig on the lab DNS server (sample domain)

4.3 Organisational Policies

Policy	Key Requirements
Information security and acceptable use policy	Defines safe use of email, internet and company devices; signed by every employee.
Email and attachment handling policy	Do not open unexpected attachments or links; verify unusual requests by phone or in person using a known number.
Incident reporting policy	Every suspected phishing email must be reported immediately (for example within 15 minutes) with a no-blame approach.
Password and MFA policy	Unique strong passwords, no reuse across sites, MFA required for email, VPN and admin accounts.
Access control (least privilege)	Users get only the access needed for their job, which limits the damage from a stolen account.
Incident response procedure	Steps to reset credentials, revoke sessions, isolate infected devices and inform management when a user is compromised.
Training and compliance policy	Mandatory training with tracking; repeat training for repeated clickers; alignment with standards such as ISO/IEC 27001 and the data-protection law (DPDP Act, 2023).

5. Immediate Response to the Campaign Findings

- Reset the passwords of the users who entered credentials and check their accounts for unusual sign-ins. In a real attack, assume these accounts are compromised.
- Check the devices of the users who downloaded the attachment, and review endpoint-protection logs.
- Handle the campaign data confidentially. Results should be reported in aggregate to management and not used to shame individuals; any credentials captured by GoPhish must be protected or discarded.
- Hold a follow-up training session for all staff within a short period while the experience is fresh.

6. Measuring Improvement

Key Indicator	Current Result	Goal for the Next Campaign (suggested)
Link click rate	40%	Reduce sharply with each campaign
Credential submission rate	20%	Move towards zero
Attachment download/open rate	Several users	Move towards zero
Reporting rate	Not measured	Measure it and increase it every quarter
Time to report	Not measured	Reduce to minutes

The targets are suggested goals for the organisation to set with management; the improvement should be tracked campaign by campaign.

7. Comparison: Weak and Strong Security Posture

Area	Weak Posture (Shown in the Report)	Strong Posture (Recommended)
User behaviour	Click links, enter passwords, open files without checking	Check sender and URL, report suspicious mail
Email security	Phishing email reaches the inbox with working link and file	SPF/DKIM/DMARC, link rewriting, sandboxing
Authentication	Password alone may give access	Phishing-resistant MFA and conditional access
Endpoints	Malicious file can be downloaded and opened	EDR, blocked file types, least privilege
Culture and policy	Reporting not part of routine	No-blame reporting, mandatory training, clear policies

8. Conclusion

The campaign shows that people are the main attack surface: a 40% click rate and a 20% credential-entry rate mean that a real phishing email would very likely succeed. The weaknesses are in awareness, technical filtering, endpoint and identity protection, and reporting culture. Because no single control is enough, the organisation should combine continuous awareness training, strong email authentication and filtering, MFA and endpoint protection, and clear policies with a no-blame reporting process. Repeating the simulation and tracking the click, submission and reporting rates will show whether the risk is falling.

Question 3 – DNS Zone Transfer (AXFR) Report Analysis (10 Marks)

> A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to

> secure the DNS infrastructure.

Answer: Security Analysis of an Open DNS Zone Transfer

1. Understanding the Scenario

The Domain Name System (DNS) translates names into IP addresses. A DNS zone is the complete set of records for a domain. A zone transfer (AXFR) is a legitimate function that lets a secondary (backup) name server copy the whole zone from the primary server. It should be allowed only to the authorised secondary servers. Dig (Domain Information Groper) is a command-line DNS tool. If the primary server answers an AXFR request from anyone, the whole zone is handed over to any requester, which is a misconfiguration and a serious information-disclosure flaw.

Facts given in the question

- The DNS assessment was done with the Dig tool.
- The DNS server allows a successful AXFR zone transfer.
- The result exposes internal hostnames, mail servers and DNS records.

Facts that are not given

The domain name, the number of records and the actual host names and IP addresses are not given. Figure 3.1 therefore uses a sample domain (`abctech.example`, a reserved example name) and documentation IP ranges, served by a lab BIND server that was deliberately left open to demonstrate the flaw.

2. Interpreting the Report

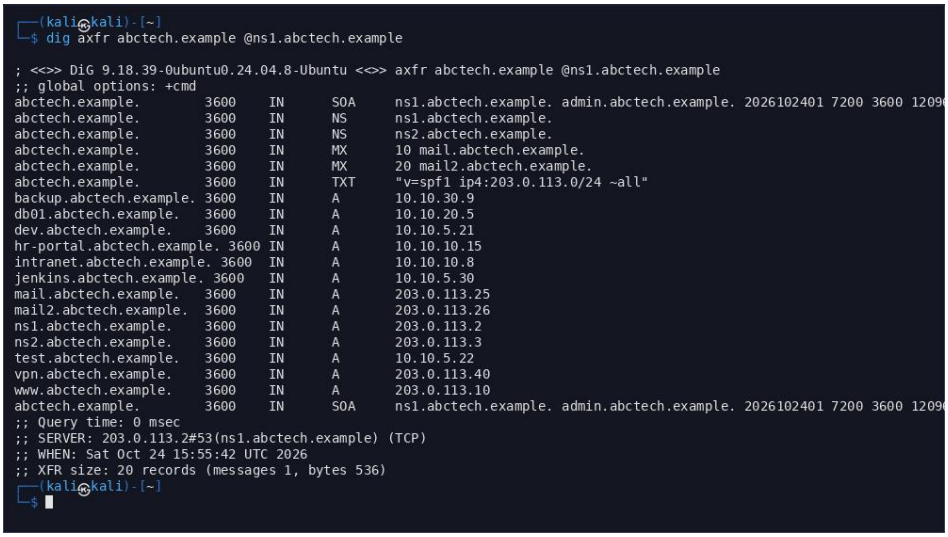


Figure: Successful zone transfer using dig axfr – lab output

Record Type	Information Exposed	Why It Matters
SOA	Primary server, administrator mailbox, serial number and timers	Reveals the DNS master and contact; the serial number shows how often the zone changes.
NS	Name servers of the domain	Shows the DNS infrastructure that can be targeted next.

Record Type	Information Exposed	Why It Matters
MX	Mail servers and their priority	Identifies mail systems for phishing, spoofing or mail-server attacks.
A records (public)	www, mail, vpn addresses	Shows internet-facing systems, including the VPN entry point.
A records (internal)	dev, test, jenkins, intranet, hr-portal, db01, backup with 10.x addresses	Exposes internal naming, structure and private IP addressing that should never be public.
TXT	SPF policy	Shows which servers may send mail and that the policy is only a soft-fail (`~all`).

The red entries in Figure 3.1 are the most serious. Private addresses and names such as `db01`, `backup`, `jenkins` and `hr-portal` should exist only in an internal DNS view. Their presence in a publicly answerable zone shows that internal and external DNS are not separated (no split-horizon DNS).

3. Security Implications of the Exposed Information

- **Complete network map for free:** the attacker gets a ready-made list of hosts, which would otherwise take a long time to find by guessing names. The zone transfer replaces noisy brute-forcing.
- **Disclosure of internal architecture:** private IP ranges (10.10.x.x), subnets and server roles show how the network is organised.
- **Target prioritisation:** names reveal function. Database, backup, CI/CD (`jenkins`) and HR systems hold the most valuable data, so the attacker knows exactly where to go first.
- **Weak systems revealed:** development and test servers (`dev`, `test`) are often less patched and use default or weak passwords.
- **Mail infrastructure revealed:** knowing the mail servers and SPF policy helps in crafting spoofed or phishing emails and in attacking the mail service.
- **Administrator contact revealed:** the SOA email gives a real contact for social engineering.
- **Possible dangling or forgotten records:** old records can point to unused hosts or services, which may lead to takeover.
- **Compliance and reputation risk:** the exposure of internal details can breach the organisation's security policy and standards, and damages trust.

Exposed Item	Impact on Confidentiality	Severity
Internal hostnames and 10.x IP addresses	High – reveals internal structure	High
Database, backup and CI/CD server names	High – shows high-value targets	High
Mail server records and SPF	Medium – helps phishing and	Medium

Exposed Item	Impact on Confidentiality	Severity
	spoofing	
SOA and NS information	Low to medium – shows DNS design and contact	Medium
Public hosts (www, vpn)	Low – normally public, but VPN is a target	Low

4. How Attackers Could Exploit the Findings

- **Step 1 – Find the name servers** of the domain by an ordinary DNS lookup (`dig NS`).
- **Step 2 – Request the zone** (`dig axfr`) from each name server. If one allows it, the whole zone is returned in seconds.
- **Step 3 – Analyse the data** to separate public and internal systems and to pick targets.
- **Step 4 – Scan and attack the discovered hosts.** They run port scans and vulnerability scans on the listed systems, and concentrate on the weakest ones such as `dev` and `test`.
- **Step 5 – Pivot to high-value systems** (`db01`, `backup`, `jenkins`) from a compromised development server, because internal servers often trust each other.
- **Step 6 – Use mail and contact data** for targeted phishing, spoofed email and social engineering against the administrators and staff.
- **Other abuse:** repeated large zone transfers can also consume server resources and slow the DNS service.

This reconnaissance can be done silently from outside the network without any password, which is why an open AXFR is rated as a significant finding even though it does not itself change any data.

5. Best Practices to Secure the DNS Infrastructure

Control	How to Apply It
Restrict zone transfers	Allow AXFR only to the IP addresses of the authorised secondary servers (`allow-transfer`); deny everyone else.
Authenticate transfers (TSIG)	Use TSIG keys so that only a server holding the shared secret can obtain a transfer, even if the IP is spoofed.
Firewall DNS (TCP/UDP 53)	Zone transfers use TCP port 53. Allow TCP 53 only between the primary and secondary servers.
Split-horizon DNS	Keep separate internal and external zones. Publish only public records on the external server; never list private addresses on the internet.
Minimise records	Remove unused, test and legacy records; do not expose descriptive names for sensitive systems on public DNS; use a role mailbox in the SOA.
Separate roles	Do not run an authoritative server and an open recursive resolver together; disable recursion on authoritative servers.
DNSSEC	Sign the zone to protect the integrity of answers against forgery and cache poisoning.

Control	How to Apply It
Hide version and limit abuse	Hide the DNS software version, apply response rate limiting, and keep BIND or other DNS software patched.
Logging and monitoring	Log AXFR requests and alert on transfers from unknown hosts; review the logs regularly.
Regular auditing	Test your own servers with `dig axfr`, `dnsrecon` or similar tools after each change, and include DNS in penetration tests.

Verification After the Fix

After the configuration is corrected, the same Dig command must fail for an unauthorised host, while the genuine secondary server can still replicate the zone



Figure: Zone transfer refused after securing the DNS server (TSIG-authenticated secondary still works)

6. Comparison: Before and After

Area	Before (Report Finding)	After (Recommended State)
Zone transfer	Any host can obtain the full zone	Only authorised secondaries with TSIG; others refused
Internal records	Private IPs and internal names visible on the internet	Internal zone kept inside; only public records published
Reconnaissance value	Complete network map available instantly	Attacker must guess names slowly and noisily
Monitoring	Transfers unnoticed	AXFR attempts logged and alerted

7. Conclusion

An open zone transfer gives an attacker the whole DNS zone: internal hostnames, mail servers, private IP addresses and the records that show where the important systems are. It does not directly change data, but it makes every later attack faster and more precise. The problem is solved by limiting AXFR to authorised secondary servers with TSIG, firewalling TCP port 53, separating internal and public DNS, removing unnecessary records, and monitoring and testing the DNS servers regularly.

Overall Summary

Question	Main Finding	Key Countermeasures

Question	Main Finding	Key Countermeasures
Q1 – Nmap (20 marks)	Exposed SSH, HTTP and MySQL with visible service versions	Firewall rules, patching, TLS, key-only SSH, restricted database, monitoring
Q2 – GoPhish (20 marks)	40% clicked, 20% gave credentials, several opened an attachment	Awareness training, email authentication and filtering, MFA, policies
Q3 – Dig AXFR (10 marks)	DNS zone freely transferable, internal records exposed	Restrict AXFR with TSIG, split-horizon DNS, monitoring

All three reports show the same lesson: footprinting collects small pieces of information (open ports, human behaviour, DNS records) that together give an attacker a clear path into an organisation. Ethical hackers perform the same footprinting with permission so that the weaknesses can be fixed first.